

Sicurezza

CdL in Informatica – L31

Lezione 1

Prof. Emiliano Casalicchio

Department of Computer Science

Sapienza University of Rome



SAPIENZA
UNIVERSITÀ DI ROMA



The NIST Internal/Interagency Report NISTIR 7298 (*Glossary of Key Information Security Terms*, May 2013) defines the term *computer security* as follows:

Measures and controls that ensure **confidentiality**, **integrity**, and **availability** of information system assets including hardware, software, firmware, and information being processed, stored, and communicated.

Domanda

- Quale e' il vostro concetto di **confidenzialita'**, **integrita'** e **Disponibilita'**?



Key objectives/requirements (CIA)

Confidentiality

- Data Confidentiality
 - Assures that private or confidential information is not made available or disclosed to unauthorized individuals.
- Privacy
 - Assures that individuals control or influence what information related to them may be collected and stored and by whom and to whom that information may be disclosed

Integrity

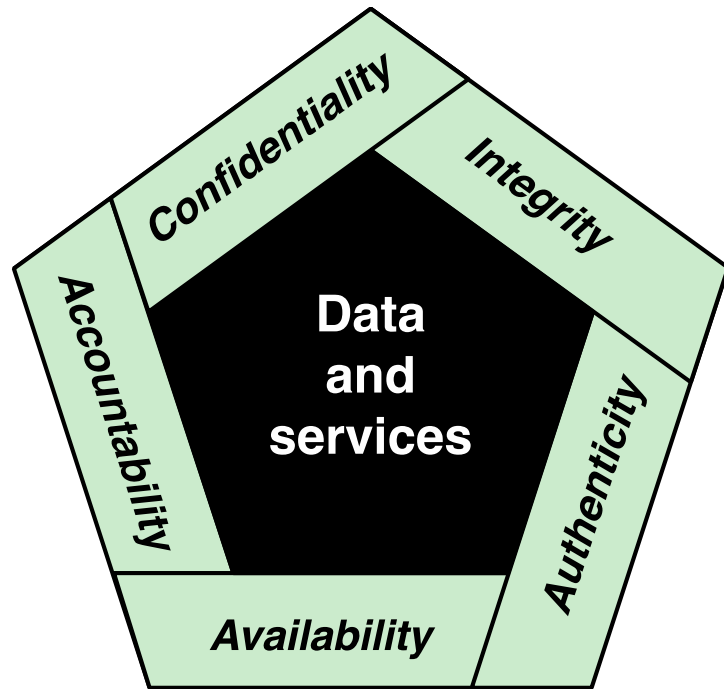
- Data Integrity
 - Assures that information and programs are changed only in a specified and authorized manner.
- System Integrity
 - Assures that a system performs its intended function in an unimpaired manner, free from deliberate or inadvertent unauthorized manipulation of the system.

Availability

- System availability
- Service availability



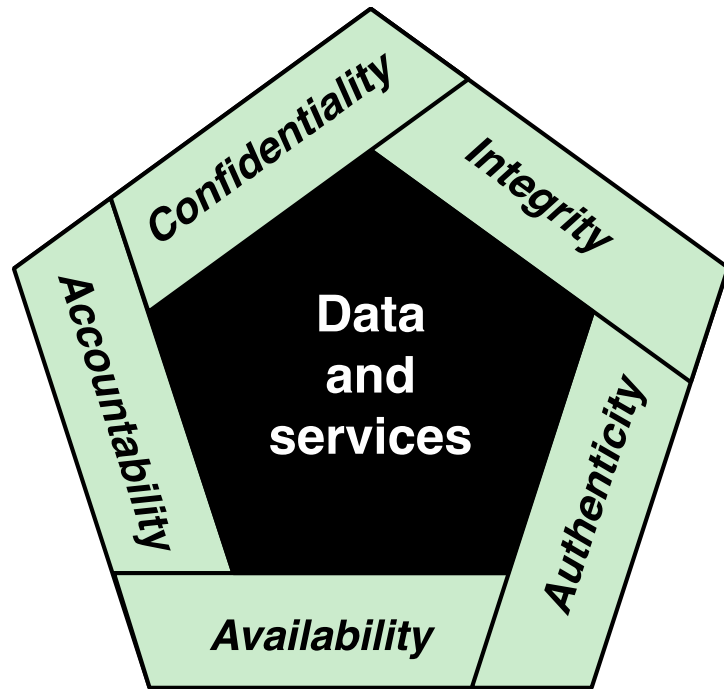
The CIA triad (+)



- Confidentiality - Preserving authorized restrictions on information access and disclosure, including means for protecting personal privacy and proprietary information.
 - **A loss of confidentiality is the unauthorized disclosure of information**

Figure 1.1 Essential Network and Computer Security Requirements

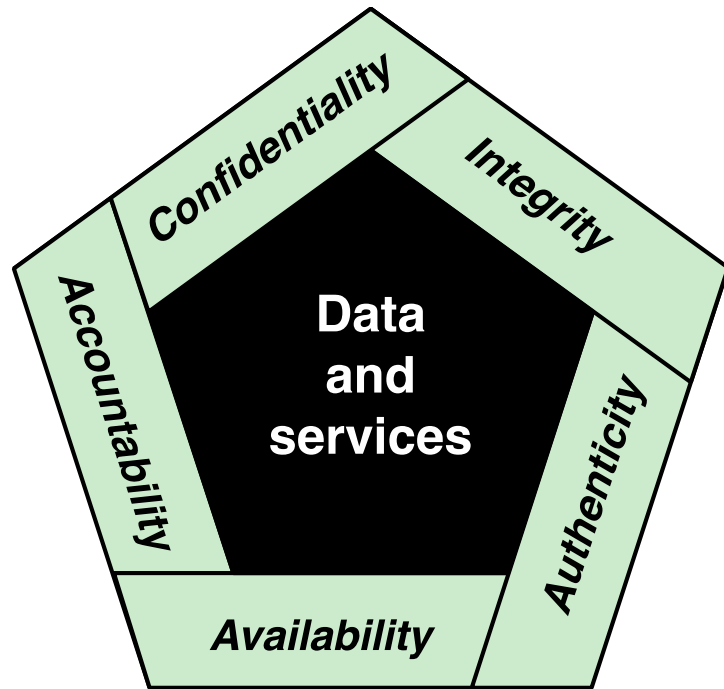
The CIA triad (+)



- Integrity - Guarding against improper information modification or destruction, Including ensuring information nonrepudiation and authenticity.
 - **A loss of integrity is the unauthorized modification or destruction of information**

Figure 1.1 Essential Network and Computer Security Requirements

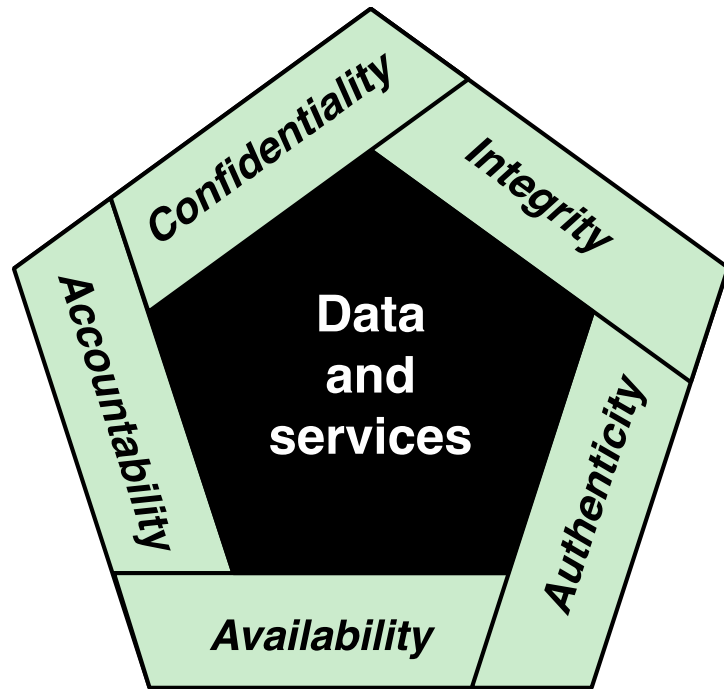
The CIA triad (+)



- Availability - Ensuring timely and reliable access to and use of information.
 - **A loss of availability is the disruption of access to or use of information or an information system**

Figure 1.1 Essential Network and Computer Security Requirements

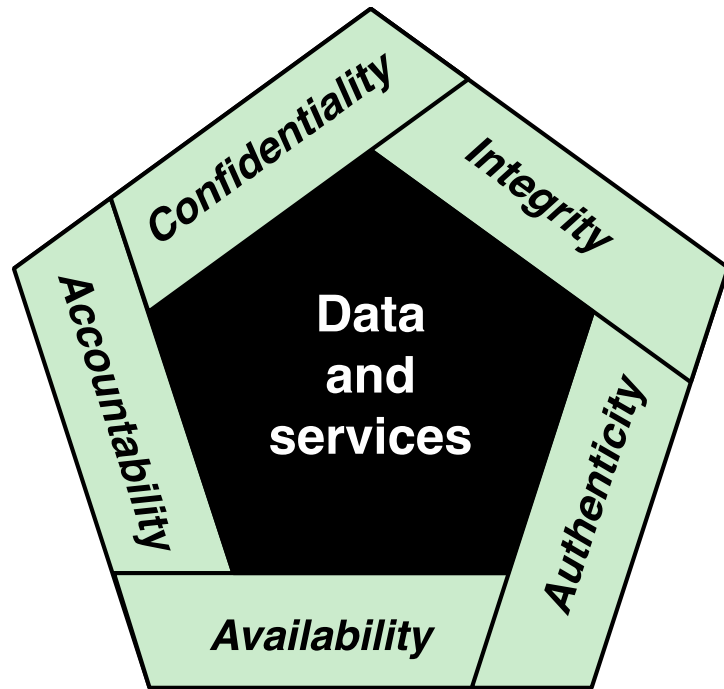
The CIA triad (+)



- **Authenticity** - The property of
 - being genuine and being able to be verified and trusted;
 - confidence in the validity of a transmission, a message, or message originator.
- This means verifying that users are who they say they are and that each input arriving at the system came from a trusted source

Figure 1.1 Essential Network and Computer Security Requirements

The CIA triad (+)



- **Accountability** The security goal that generates the requirement for actions of an entity to be traced uniquely to that entity.
- This supports
 - nonrepudiation,
 - deterrence,
 - fault isolation,
 - intrusion detection and prevention,
 - action recovery and legal action.
- We must be able to trace a security breach to a responsible party.
- Systems must keep records of their activities to permit later forensic analysis to trace security breaches or to aid in transaction disputes.

Figure 1.1 Essential Network and Computer Security Requirements

Levels of Impact

Low

The loss could be expected to have a **limited adverse effect** on organizational operations, organizational assets, or individuals

Moderate

The loss could be expected to have a **serious adverse effect** on organizational operations, organizational assets, or individuals

High

The loss could be expected to have a **severe or catastrophic adverse effect** on organizational operations, organizational assets, or individuals

Low impact level

- For an organization, the loss of CIA might
 - (i) cause a degradation in mission capability to an extent and duration that the organization is able to perform its primary functions, but the effectiveness of the functions is **noticeably reduced**;
 - (ii) result in minor damage to organizational assets;
 - (iii) result in minor financial loss; or
 - (iv) result in minor harm to individuals.



Moderate Impact Level

- For an organization, the loss of CIA might
 - (i) cause a significant degradation in mission capability to an extent and duration that the organization is able to perform its primary functions, but the effectiveness of the functions is **significantly reduced**;
 - (ii) result in significant damage to organizational assets;
 - (iii) result in significant financial loss; or
 - (iv) result in significant harm to individuals that does not involve loss of life or serious, life-threatening injuries.



High Impact Level

- For an organization, the loss of CIA might
 - (i) cause a severe degradation in or loss of mission capability to an extent and duration that the **organization is not able to perform** one or more of its primary functions;
 - (ii) result in major damage to organizational assets;
 - (iii) result in major financial loss; or
 - (iv) result in severe or catastrophic harm to individuals involving loss of life or serious life-threatening injuries.



Examples

- Low Impact:
 - Loss of confidentiality for Directory information
 - Loss of integrity of an anonymous online pool
 - Loss of availability for a online telefon directory lookup application
- Moderate Impact:
 - Loss of confidentiality for student enrollment information
 - Loss of Integrity for an online forum
 - Loss of availability for a university web site providing information for current and prospective students and donors.
- High Impact
 - Loss of confidentiality of classified information (industrial/military)
 - Loss of integrity for a Database of medical record
 - Loss of availability of an authentication services for critical systems, applications, and devices



E' il vostro turno!!

- Low Impact
- Moderate Impact
- High Impact



- Quali sono le sfide (I challenge) della computer security secondo voi?



Computer Security Challenges

1. Computer security is not as simple as it might first appear to the novice

2. In developing a particular security mechanism or algorithm, one must always consider potential attacks on those security features

3. Procedures used to provide particular security services are often counterintuitive

Computer Security Challenges

4. Physical and logical placement needs to be determined

5. Security mechanisms typically involve more than a particular algorithm or protocol and also require that participants be in possession of some secret information which raises questions about the creation, distribution, and protection of that secret information

Computer Security Challenges

6. Attackers only need to find a single weakness, while the designer must find and eliminate all weaknesses to achieve perfect security

7. Security is still too often an afterthought to be incorporated into a system after the design is complete, rather than being an integral part of the design process

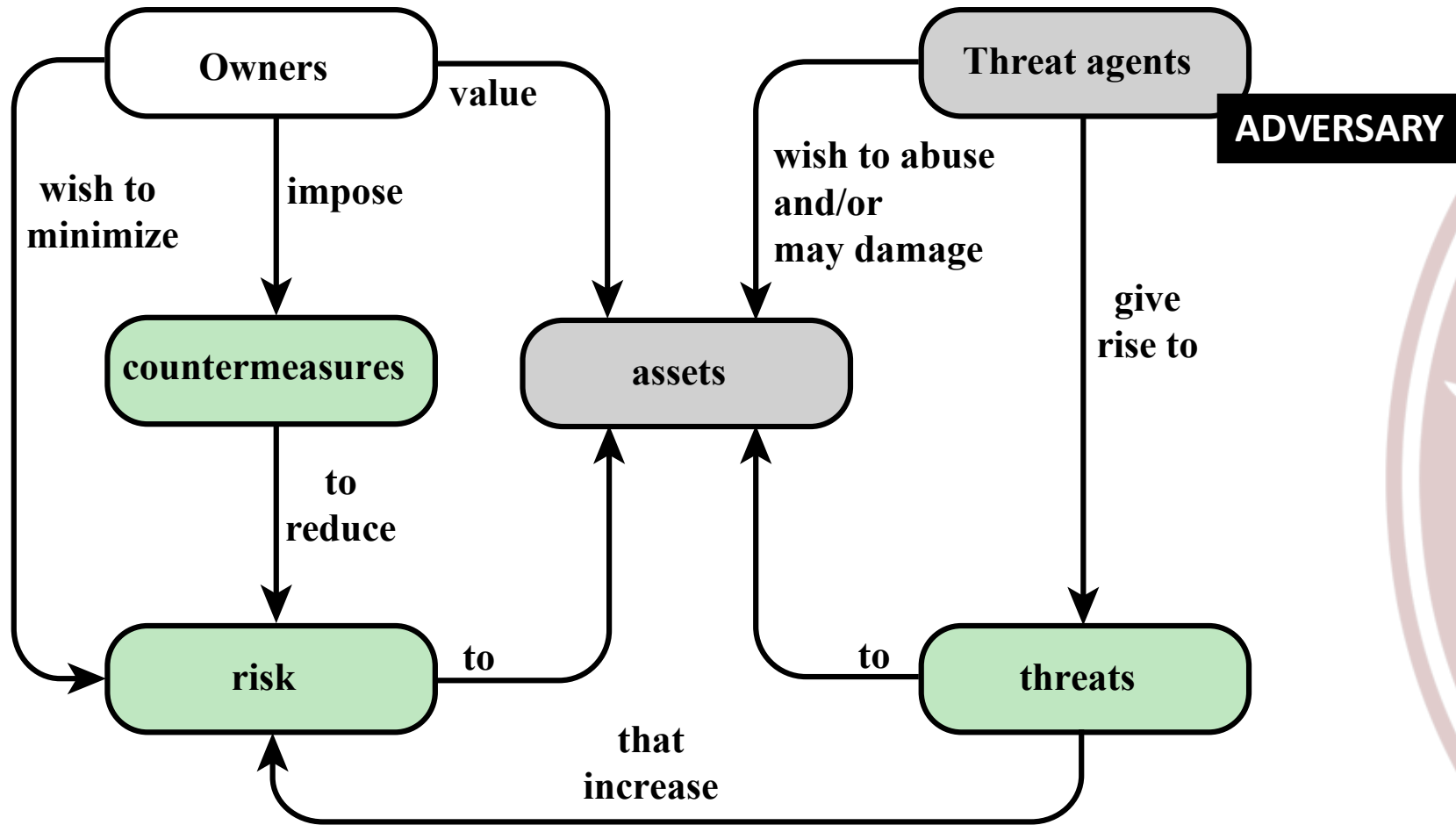
8. Security requires regular and constant monitoring

Computer Security Challenges

9. There is a natural tendency on the part of users and system managers to perceive little benefit from security investment until a security failure occurs

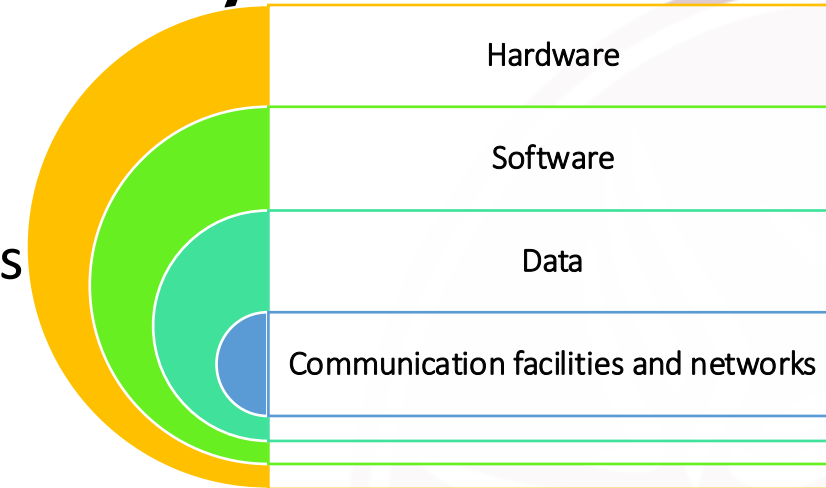
10. Many users and even security administrators view strong security as an impediment to efficient and user-friendly operation of an information system or use of information

Un modello per la Computer Security



Un modello per la Computer Security

- System Resource (Asset)
 - HW, SW, Data, Communication facilities and networks
- Vulnerability (of an Asset)
 - Weakness in an information system, system security procedures, internal controls, or implementation that could be exploited or triggered by a threat source
 - General categories of vulnerabilities. A system could be
 - Corrupted
 - Leaky
 - Unavailable



Un modello per la Computer Security (cont'd)

- Threat
 - Any circumstance or event with the potential to adversely impact organizational operations (including mission, functions, image, or reputation), organizational assets, individuals, other organizations, or the Nation through an information system via unauthorized access, destruction, disclosure, modification of information, and/or denial of service.
- Adversary (threat agent)
 - Individual, group, organization, or government that conducts or has the intent to conduct detrimental activities.

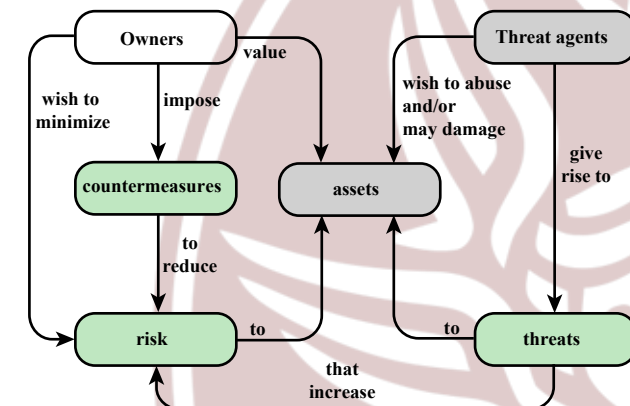


Figure 1.2 Security Concepts and Relationships

Un modello per la Computer Security (cont'd)

- Attack
 - Any kind of malicious activity that attempts to collect, disrupt, deny, degrade, or destroy information system resources or the information itself.
- Countermeasure
 - A device or techniques that has as its objective the impairment of the operational effectiveness of undesirable or adversarial activity, or the prevention of espionage, sabotage, theft, or unauthorized access to or use of sensitive information or information systems.

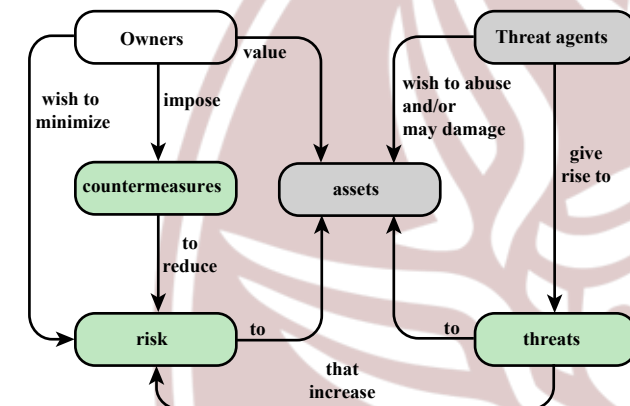


Figure 1.2 Security Concepts and Relationships

Un modello per la Computer Security (cont'd)

- Risk
 - A measure of the extent to which an entity is threatened by a potential circumstance or event, and typically a function of
 - 1) the adverse impacts that would arise if the circumstance or event occurs (**D**); and
 - 2) the likelihood of occurrence (**P**).
 - **$R = P \times D$**
- Security Policy
 - A set of criteria for the provision of security services. It defines and constrains the activities of a data processing facility in order to maintain a condition of security for systems and data.

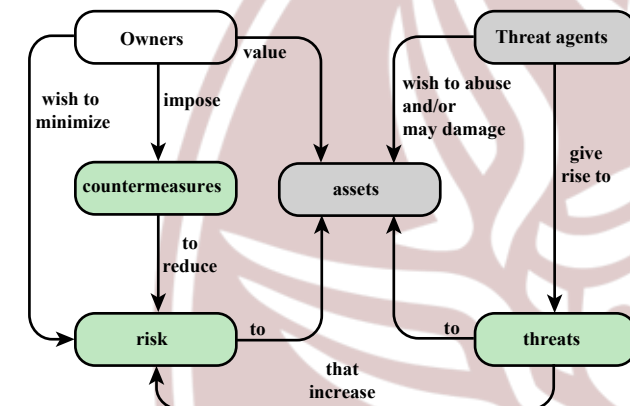


Figure 1.2 Security Concepts and Relationships

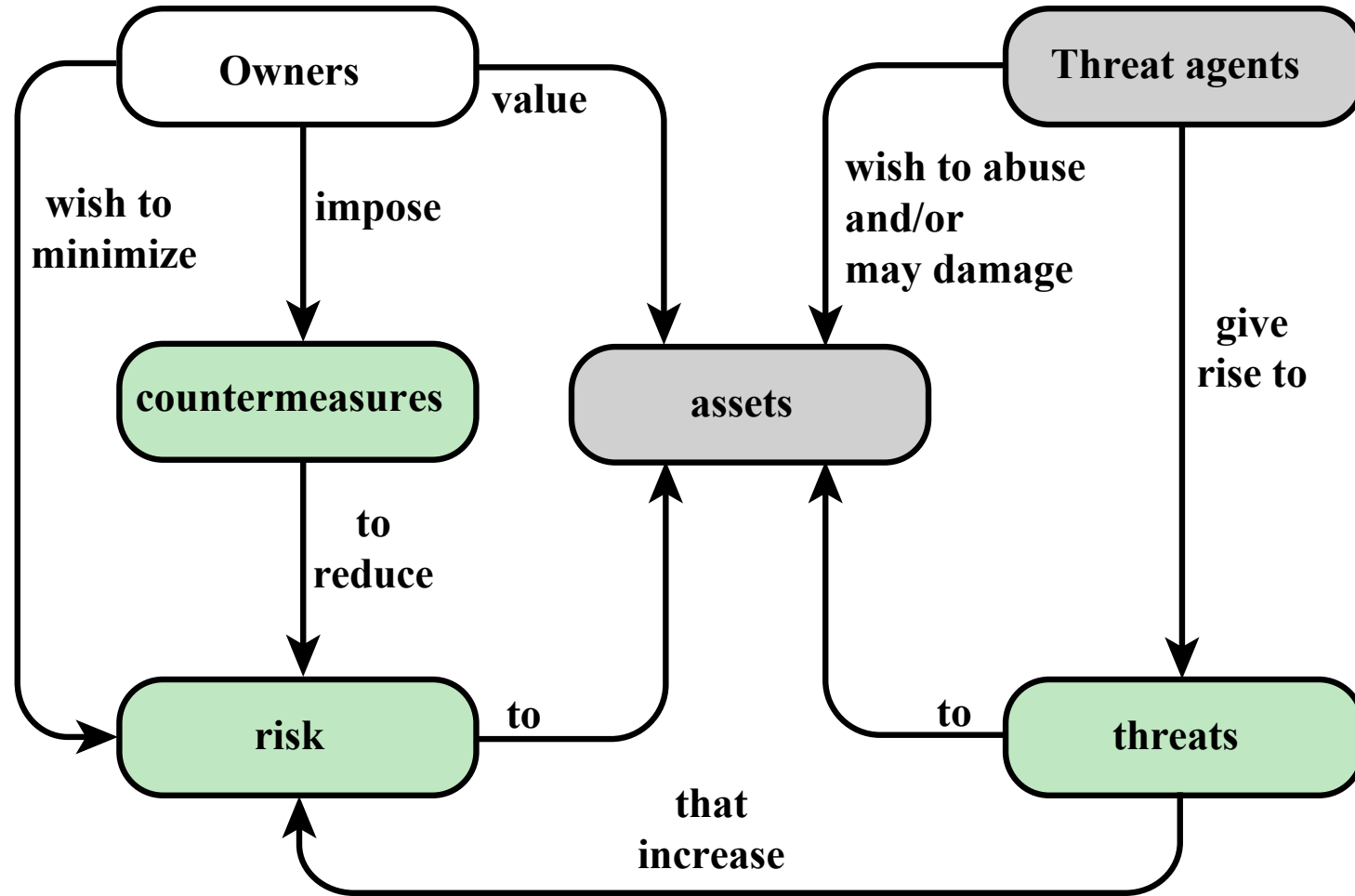


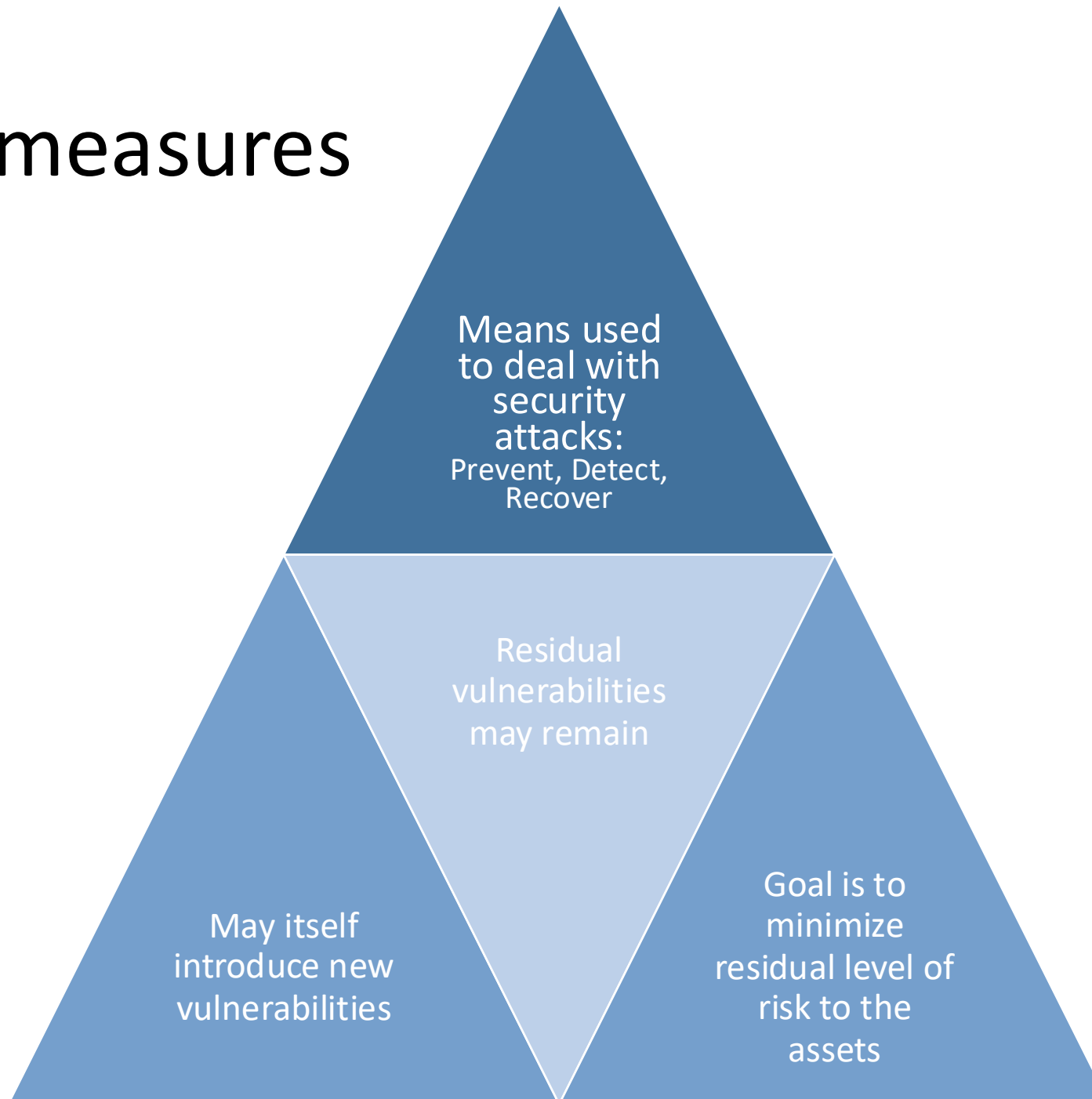
Figure 1.2 Security Concepts and Relationships

Vulnerabilities, Threats and Attacks

- Categories of vulnerabilities
 - Corrupted (loss of integrity)
 - Leaky (loss of confidentiality)
 - Unavailable or very slow (loss of availability)
- Threats
 - Capable of exploiting vulnerabilities
 - Represent potential security harm to an asset
- Attacks (threats carried out)
 - Passive – attempt to learn or make use of information from the system that does not affect system resources
 - Active – attempt to alter system resources or affect their operation
 - Insider – initiated by an entity inside the security perimeter
 - Outsider – initiated from outside the perimeter



Countermeasures



Minacce e attacchi

Conseguenze di minacce e tipi di attacco che producono tali conseguenze (RFC4949)

Threat consequences

- Unauthorized disclosure
- Deception
- Disruption
- Usurpation



Minacce e attacchi

Conseguenze di minacce e tipi di attacco che producono tali conseguenze (RFC4949)

Threat Consequence	Threat Action (Attack)
Unauthorized Disclosure A circumstance or event whereby an entity gains access to data for which the entity is not authorized.	Exposure: Sensitive data are directly released to an unauthorized entity. Interception: An unauthorized entity directly accesses sensitive data traveling between authorized sources and destinations. Inference: A threat action whereby an unauthorized entity indirectly accesses sensitive data (but not necessarily the data contained in the communication) by reasoning from characteristics or byproducts of communications. Intrusion: An unauthorized entity gains access to sensitive data by circumventing a system's security protections.

Minacce e attacchi

Conseguenze di minacce e tipi di attacco che producono tali conseguenze (RFC4949)

Deception

A circumstance or event that may result in an authorized entity receiving false data and believing it to be true.

Masquerade: An unauthorized entity gains access to a system or performs a malicious act by posing as an authorized entity.

Falsification: False data deceive an authorized entity.

Repudiation: An entity deceives another by falsely denying responsibility for an act.

Minacce e attacchi

Conseguenze di minacce e tipi di attacco che producono tali conseguenze (RFC4949)

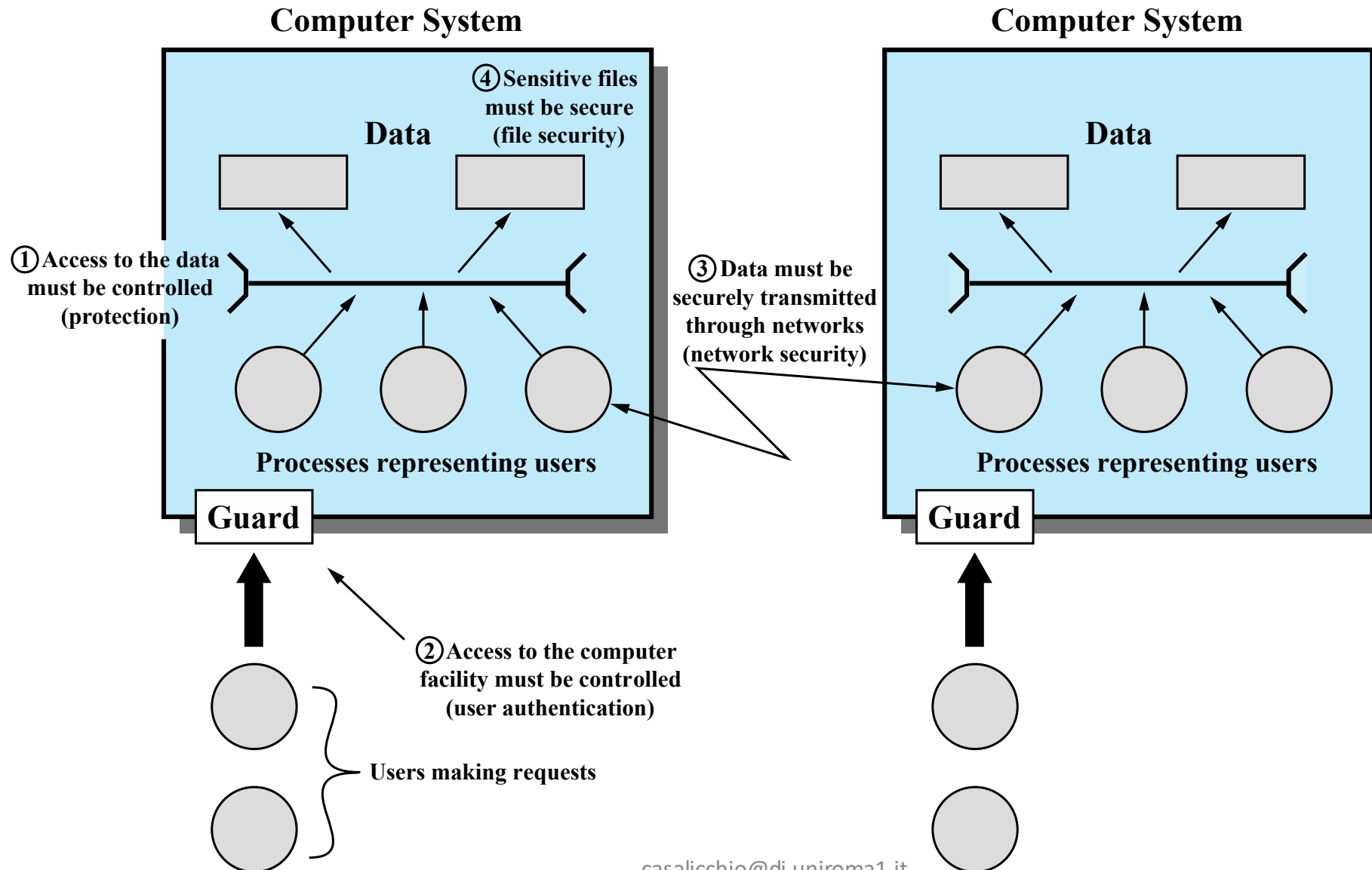
Disruption A circumstance or event that interrupts or prevents the correct operation of system services and functions.	Incapacitation: Prevents or interrupts system operation by disabling a system component. Corruption: Undesirably alters system operation by adversely modifying system functions or data. Obstruction: A threat action that interrupts delivery of system services by hindering system operation.
--	--

Minacce e attacchi

Conseguenze di minacce e tipi di attacco che producono tali conseguenze (RFC4949)

Usurpation A circumstance or event that results in control of system services or functions by an unauthorized entity.	Misappropriation: An entity assumes unauthorized logical or physical control of a system resource. Misuse: Causes a system component to perform a function or service that is detrimental to system security.
---	--

Minacce e Risorse (threats and assets)



Computer and Network Assets, with Ex. of Threats

	Availability	Confidentiality	Integrity
Hardware	1	2	
Software	3	4	5
Data	6	7	8
Communication Lines and Networks	9	10	11



Table 1.3
Computer and Network Assets, with Examples of Threats

	Availability	Confidentiality	Integrity
Hardware	Equipment is stolen or disabled, thus denying service.	An unencrypted CD-ROM or DVD is stolen.	
Software	Programs are deleted, denying access to users.	An unauthorized copy of software is made.	A working program is modified, either to cause it to fail during execution or to cause it to do some unintended task.
Data	Files are deleted, denying access to users.	An unauthorized read of data is performed. An analysis of statistical data reveals underlying data.	Existing files are modified or new files are fabricated.
Communication Lines and Networks	Messages are destroyed or deleted. Communication lines or networks are rendered unavailable.	Messages are read. The traffic pattern of messages is observed.	Messages are modified, delayed, reordered, or duplicated. False messages are fabricated.

Passive and Active Attacks

Passive attacks

- Attempts to learn or make use of information from the system but does not affect system resources
- Eavesdropping on, or monitoring of, transmissions
- Goal of attacker is to obtain information that is being transmitted
- Two types:
 - Release of message contents
 - Traffic analysis

Active attacks

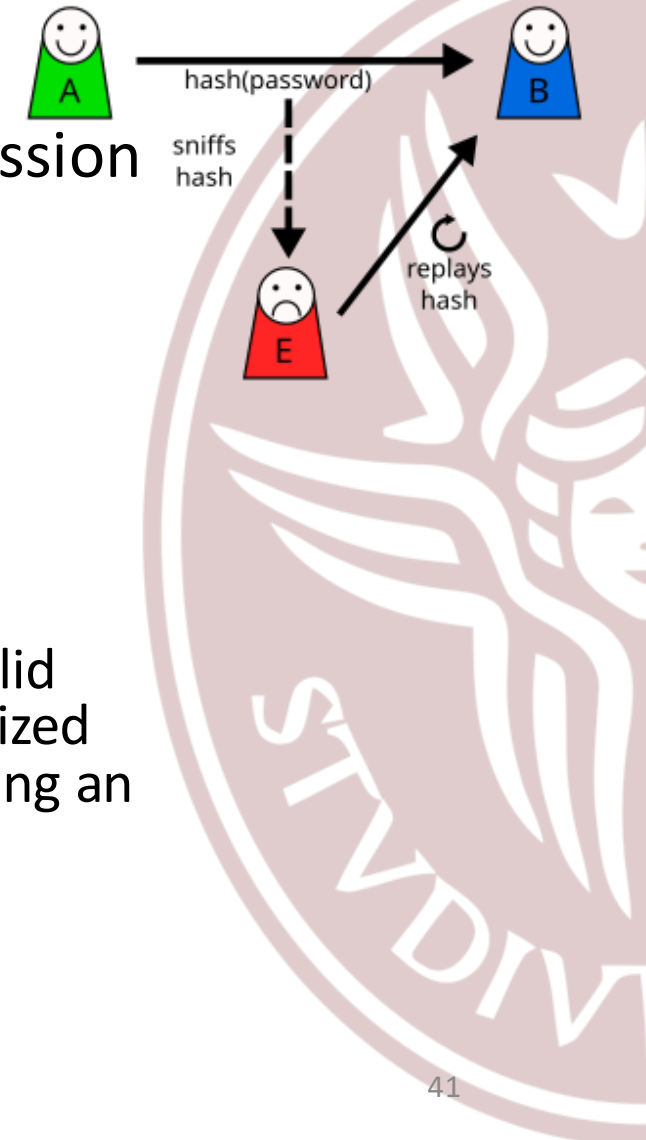
- Attempts to alter system resources or affect their operation
- Involve some modification of the data stream or the creation of a false stream
- Four categories:
 - Replay
 - Masquerade
 - Modification of messages
 - Denial of service



Categories of Active Attacks

Replay

- passive capture of a data unit and its subsequent retransmission to produce an unauthorized effect



Masquerade

- one entity pretends to be a different entity.
- Includes other forms of active attacks to obtain credential
 - authentication sequences can be captured and replayed after a valid authentication sequence has taken place, thus enabling an authorized entity with few privileges to obtain extra privileges by impersonating an entity that has those privileges
 - Operation Aurora; Equifax Data Breach

Categories of Active Attacks (cont'd)

Modification of messages

- some portion of a legitimate message is altered, or that messages are delayed or reordered, to produce an unauthorized effect.
- Example,
 - “Allow John Smith to read confidential file accounts” → “Allow Fred Brown to read confidential file accounts.”

Denial of service

- prevents or inhibits the normal use or management of communications facilities.
- Examples,
 - an entity may suppress all messages directed to a particular destination (e.g., the security audit service).
 - the disruption of an entire network, either by disabling the network or by overloading it with messages so as to degrade performance.

Requisiti di sicurezza (Security requirements)

- Contromisure alle vulnerabilità e minacce possono essere classificate e categorizzate in differenti modi
- Un approccio e' classificare le contromisure in funzione dei requisiti funzionali (*FIPS 200 - Minimum Security Requirements for Federal Information and Information Systems*)
 - 17 aree di contromisure per protezione CIA
 - Contromisure tecniche
 - Contromisure funzionali (gestione della sicurezza)
 - Insieme di contromisure Tecniche e funzionali

"If you think technology can solve your security problems, then you don't understand the problems and you don't understand the technology"
[SCHN00]



Requisiti di sicurezza tecnici

- Controllo degli accessi (access control)
- Identificazione e autenticazione (Identification and Authentication)
- Protezione dei sistemi e delle comunicazioni (Systems and Communication Protection)
- Integrità del sistema e delle informazioni (Systems and Information Integrity)



Requisiti di sicurezza funzionali

- Consapevolezza e formazione (Awareness and Training)
- Controllo e responsabilizzazione (Audit and Accountability)
- Certificazione, accreditamento e valutazione di sicurezza (Certification, Accreditation and Security Assessment)
- Pianificazione dell'emergenza (Contingency Planning)
- Manutenzione (Maintenance)
- Protezione fisica e ambientale (Physical and Environmental protection)
- Pianificazione (Planning)
- Sicurezza del personale (Personnel Security)
- Valutazione dei rischi (Risk Assessment)
- Acquisizione dei sistemi e servizi (Systems and Service Acquisition)

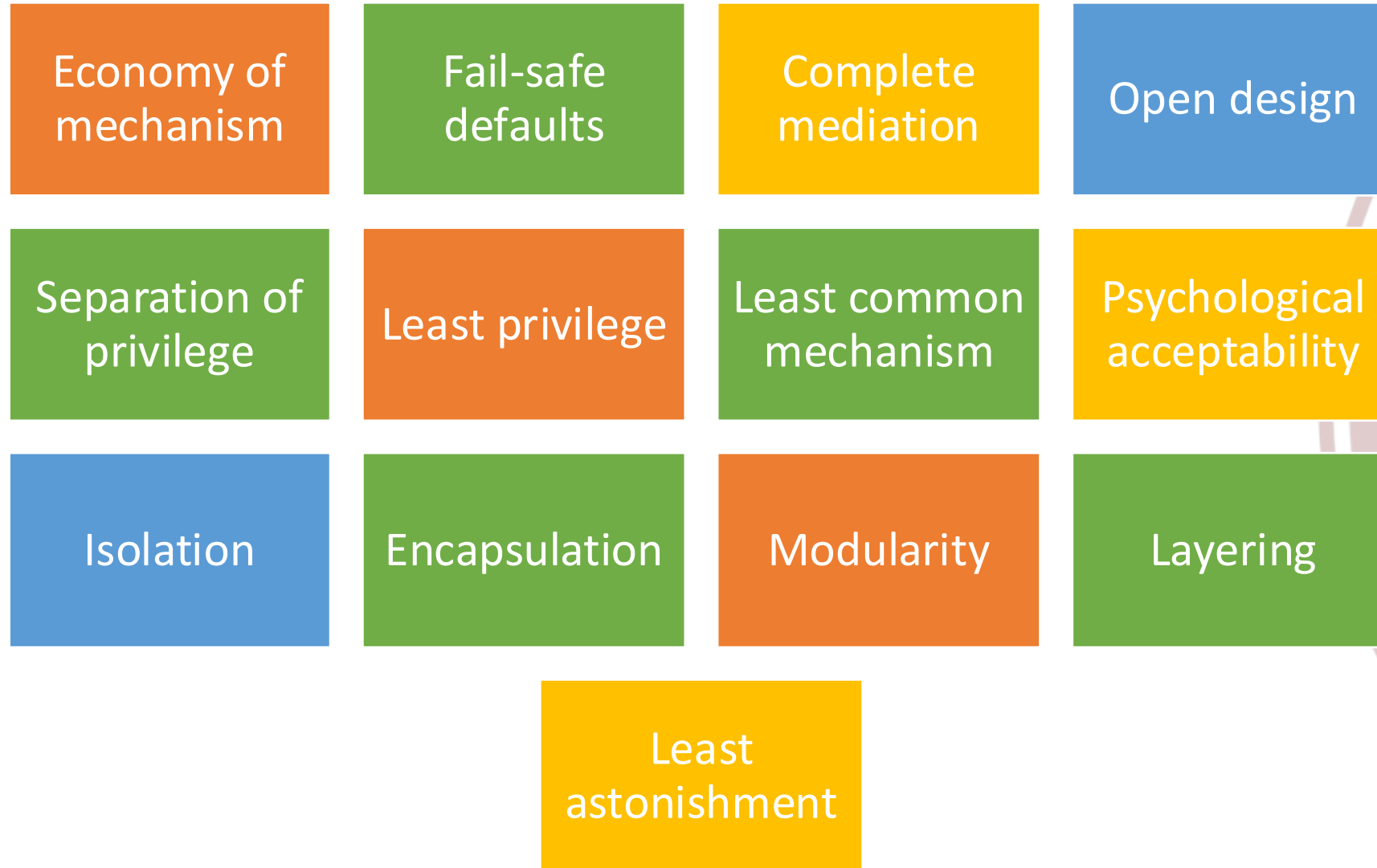


Requisiti di sicurezza funzionali+tecnici (overlap)

- Gestione della configurazione (Configuration management)
- Risposta agli incidenti (Incident Response)
- Protezione dei media (Media Protection)



Fundamental Security Design Principles



Security Design Principles

- Economy of mechanisms
 - the design of security measures embodied in both hardware and software should be as simple and small as possible
 - Easy to test and verify
 - Easy to update and replace
- Fail-safe default
 - access decisions should be based on permission rather than exclusion.
 - The default situation is lack of access, and the protection scheme identifies conditions under which access is permitted
- Complete mediation
 - every access must be checked against the access control mechanism.
 - systems should not rely on access decisions retrieved from a cache.
 - in a system designed to operate continuously, this principle requires that, if access decisions are remembered for future use, careful consideration be given to how changes in authority are propagated into such local memories



Security Design Principles (cont'd)

- Open design
 - the design of a security mechanism should be open rather than secret
- Separation of privilege
 - a practice in which multiple privilege attributes are required to achieve access to a restricted resource
 - Esempio
 - MFA
 - Apply also to any technique in which a program is divided into parts that are limited to the specific privileges they require in order to perform a specific task. This is used to mitigate the potential damage of a computer security attack



Security Design Principles (cont'd)

- Least privilege
 - every process and every user of the system should operate using the least set of privileges necessary to perform the task
 - E.g.
 - Role Based Access Control
- Least common mechanism
 - the design should minimize the functions shared by different users, providing mutual security
 - reduce the number of unintended communication paths
 - reduces the amount of hardware and software on which all users depend



Security Design Principles (cont'd)

- Psychological acceptability
 - the security mechanisms should not interfere unduly with the work of users, while at the same time meeting the needs of those who authorize access
- Isolation (applies in three contexts)
 - public access systems should be isolated (physically or logically) from critical resources
 - the processes and files of individual users should be isolated from one another except where it is explicitly desired
 - security mechanisms should be isolated in the sense of preventing access to those mechanisms



Security Design Principles (cont'd)

- Encapsulation
 - as a specific form of isolation based on object-oriented functionality.
- Modularity
 - development of security functions as separate protected modules
 - to provide common security functions and services, such as cryptographic functions, as common modules
 - use of a modular architecture for mechanism design and implementation
 - each security mechanism should be able to support migration to new technology or upgrade of new features without requiring an entire system redesign



Security Design Principles (cont'd)

- Layering (defense in depth)
 - use of multiple, overlapping protection approaches addressing the people, technology, and operational aspects of information systems
 - Provide multiple barriers between adversary and protected information or services
 - the failure or circumvention of any individual protection approach will not leave the system unprotected
- Least astonishment
 - a program or user interface should always respond in the way that is least likely to astonish the user



Esercizio

- Consideriamo il seguente frammento di codice per controllare l'accesso ad una risorsa
- Individuare e spiegare la falla di sicurezza
- Riscrivere il codice per rimuovere la vulnerabilità'

```
DWORD dwRet = IsAccessAllowed(...);  
if (dwRet == ERROR_ACCESS_DENIED) {  
    // Security check failed.  
    // Inform user that access is denied.  
} else {  
    // Security check OK.  
}
```

Consist of the reachable and exploitable vulnerabilities in a system

Attack Surfaces

Examples:

Open ports on outward facing Web and other servers, and code listening on those ports

Services available on the inside of a firewall

Code that processes incoming data, email, XML, office documents, and industry-specific custom data exchange formats

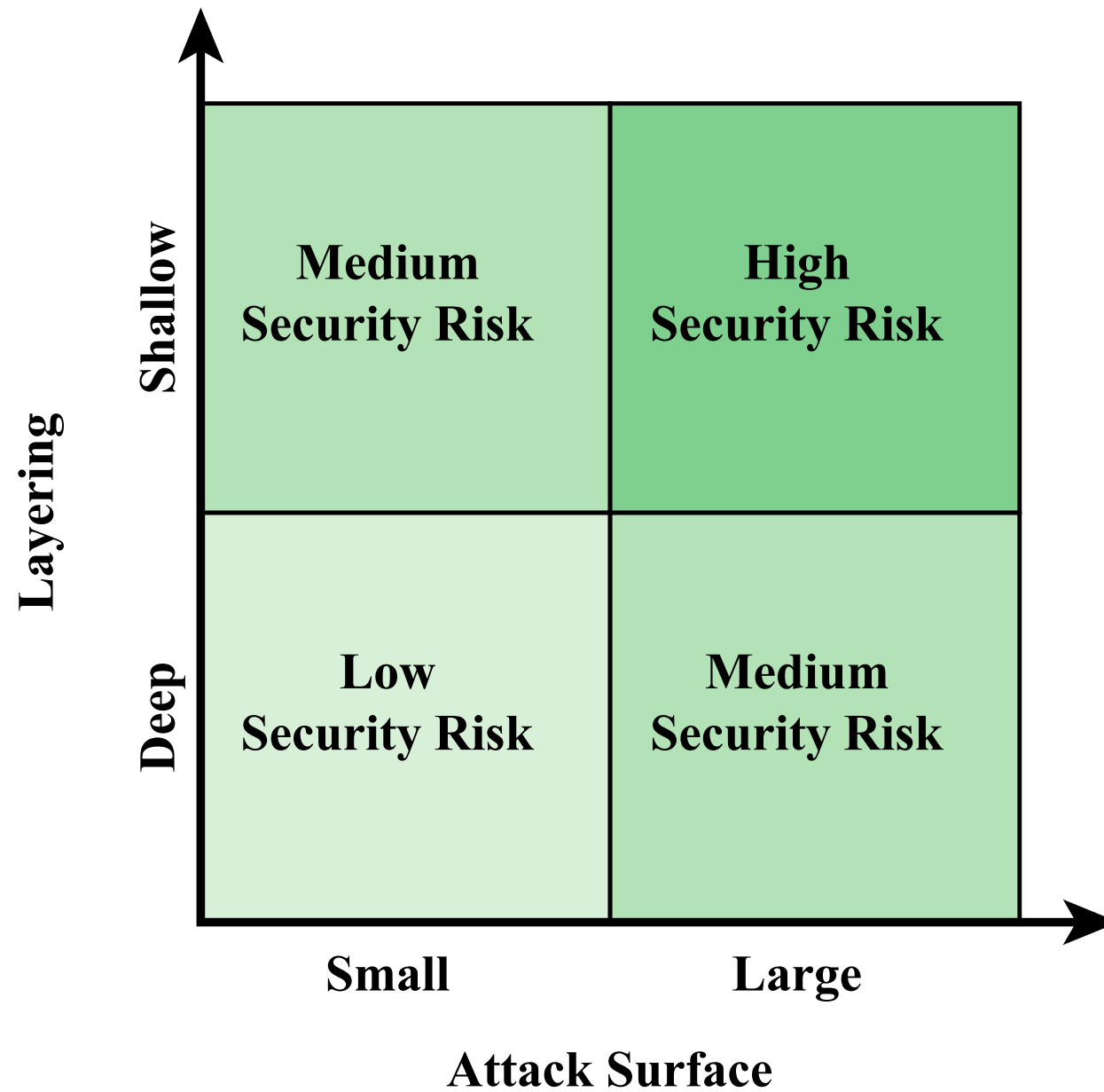
Interfaces, SQL, and Web forms

An employee with access to sensitive information vulnerable to a social engineering attack

Attack surface categories

- Network attack surface
 - network protocol vulnerabilities, such as those used for a denial-of-service attack, disruption of communications links, and various forms of intruder attacks.
- Software attack surface
 - vulnerabilities in application, utility, or operating system code. A particular focus in this category is Web server software.
- Human attack surface
 - vulnerabilities created by personnel or outsiders, such as social engineering, human error, and trusted insiders.





Alberi di attacco

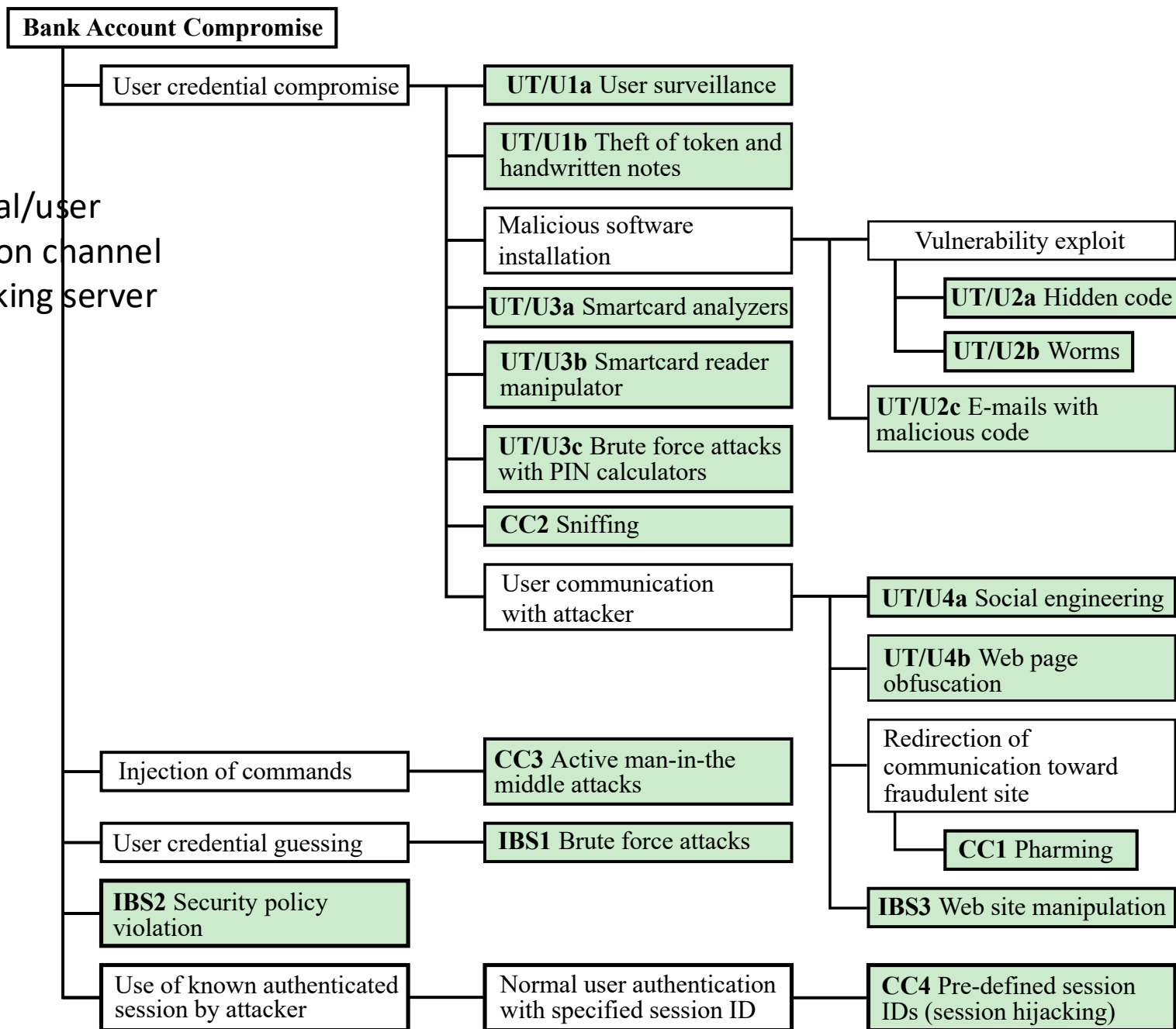
- Struttura dati gerarchica e ramificata che rappresenta un insieme di tecniche per sfruttare le vulnerabilità di sicurezza
- Radice = Obiettivo dell'attacco / incidente di sicurezza
- Nodi intermedi = sotto-obiettivi
 - AND
 - OR
- Foglie = diversi modi per iniziare l'attacco



Example Attack Tree for Application Security



UT/U user terminal/user
 CC communication channel
 IBS internet banking server



Objective: Gain unauthorized control of a smart home system.

- Attack Tree Structure
- **Root Node:** Gain control of smart home devices
 - **Branch 1:** Exploit weak Wi-Fi network security
 - **Sub-branch:** Crack Wi-Fi password using brute force
 - **Sub-branch:** Exploit outdated router firmware vulnerabilities
 - **Branch 2:** Compromise a smart device
 - **Sub-branch:** Access device through a known exploit in the firmware
 - **Sub-branch:** Steal default credentials left unchanged
 - **Branch 3:** Access smart home control hub remotely
 - **Sub-branch:** Exploit weak API authentication
 - **Sub-branch:** Hijack communication with the mobile app



Exercises

- **Design attack trees for the following Objectives**

1. Steal customer funds by breaching an online banking system.
2. Steal sensitive patient records from a healthcare organization.



Computer Security Strategies

Involve three aspects

- Specification/policy:
 - What is the security scheme supposed to do?
- Implementation/mechanisms:
 - How does it do it?
- Correctness/assurance:
 - Does it really work?
 - §



Security Policy

- *At least* - An informal description of desired system behavior. Such informal policies may reference requirements for security, integrity, and availability
- *Better if* - Formal statement of rules and practices that specify or regulate how a system or organization provides security services to protect sensitive and critical system resources
- To be considered
 - Value of assets, Vulnerabilities, Threats & Attacks
 - Ease of Use vs Security
 - Cost of Security vs Cost of failure and recovery



Security Implementation

- Prevention
- Detection
- Response
 - If security mechanisms detect an ongoing attack the system may be able to respond in such a way as to halt the attack and prevent further damage
- Recovery



Assurance

- The degree of confidence one has that the security measures, both technical and operational, work as intended to protect the system and the information it processes. This encompasses both system design and system implementation
- Assurance deals with the questions
 - “Does the security system design meet its requirements?”
 - “Does the security system implementation meet its specifications?”
- Assurance is expressed as a degree of confidence, not in terms of a formal proof that a design or implementation is correct



Evaluation

- The process of examining a computer product or system with respect to certain criteria.
- Involves
 - testing
 - formal analytic or mathematical techniques.
- *(research/industry) development of evaluation criteria that can be applied to any security system (encompassing security services and mechanisms) and that are broadly supported for making product comparisons*



Summary

- Computer security concepts
 - Definition
 - Challenges
 - Model
- Threats, attacks, and assets
 - Threats and attacks
 - Threats and assets
- Security functional requirements
- Fundamental security design principles
- Attack surfaces and attack trees
 - Attack surfaces
 - Attack trees
- Computer security strategy
 - Security policy
 - Security implementation
 - Assurance and evaluation